

BOLA / IDOR AUTHORIZATION TESTING METHODOLOGY

Object identifier manipulation and server-side ownership validation testing

Field	Details
Module	Sub-Project 2 - API Security Testing Lab
Document Type	Individual API Security Methodology PDF
Phase / Test Case	Phase 4 - Authorization Testing
Prepared For	GitHub Portfolio Documentation
Prepared By	Jagriti Banerjee
Repository	Enterprise-Security-Assessment-Lab
GitHub Filename	04-bola-idor-authorization-testing-methodology-report.pdf

This document is a professional, evidence-driven explanation of one API security methodology section. It is designed for portfolio review and contains only authorized lab-based testing context. Sensitive token values, account data, cookies, and private identifiers are redacted or intentionally represented with placeholders.

1. Section Overview

Area	Details
Phase	Phase 4 - Authorization Testing
Objective	Check whether an authenticated user can access another user's object by modifying an object identifier in the API request.
Primary Result	Evidence captured and methodology documented
GitHub Folder	02-api-security/reports/methodology/

Why this section matters

This test directly targets one of the most important API risks: the difference between authentication and authorization. A user can be logged in but still should not be able to access objects they do not own.

2. Evidence Embedded in This PDF

Evidence 1: 05-bola-accessing-another-user-data.png

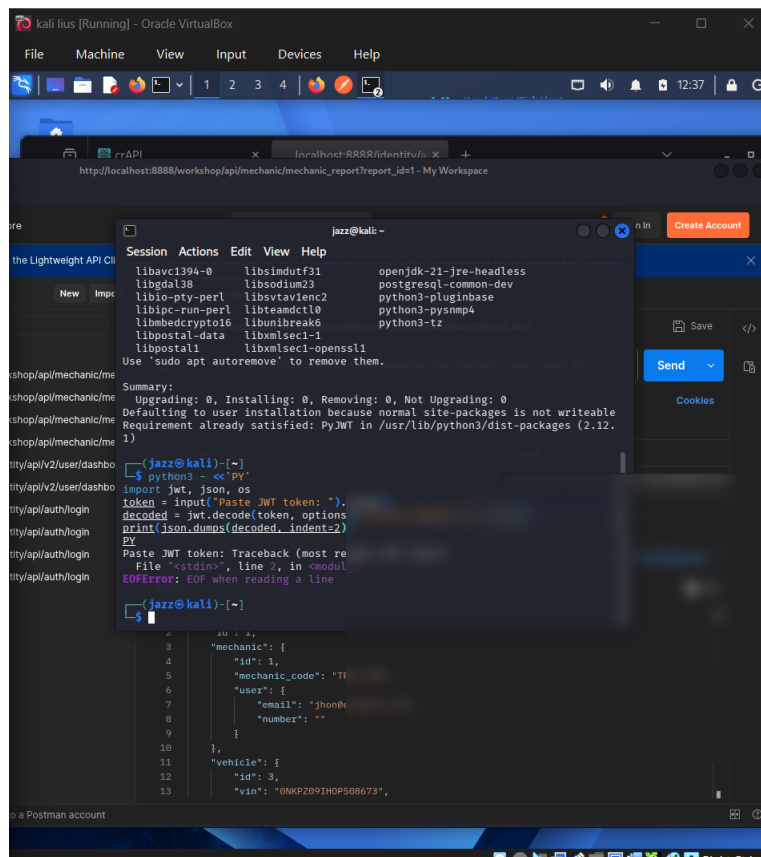


Figure 1 - Evidence showing BOLA/IDOR-style access behaviour in the lab environment.

Evidence showing BOLA/IDOR-style access behaviour in the lab environment.

3. Command and Workflow Used

```
GET /api/resource/{object_id}
Authorization: Bearer <REDACTED_TOKEN>

# Test flow
Original object ID -> owned resource
Modified object ID -> another user's resource

# Example structure only - final endpoint depends on lab route
curl -H "Authorization: Bearer <REDACTED_TOKEN>" \
  http://127.0.0.1:8888/api/resource/<MODIFIED_OBJECT_ID>
```

Step-by-step workflow

- Authenticated as a normal lab user.
- Requested a resource owned by the current user.
- Modified the object identifier to reference a different user or object.
- Observed whether the API returned unauthorized data or rejected the request.
- Captured evidence of the observed authorization behaviour.

4. Professional Interpretation

This test directly targets one of the most important API risks: the difference between authentication and authorization. A user can be logged in but still should not be able to access objects they do not own.

5. Security Risk and Impact

If present in production, BOLA/IDOR can expose private user data, vehicle records, invoices, reports, orders, or account details. It is often high impact because exploitation may require only changing a numeric or predictable object ID.

6. Recommended Remediation and Hardening

- Perform server-side object ownership checks on every object access request.
- Do not rely on client-side filtering or hidden UI elements.
- Use authorization middleware that checks authenticated user context against the requested object owner.
- Avoid predictable object identifiers where possible.
- Log denied object-access attempts and investigate repeated enumeration patterns.

7. Framework Mapping

Framework Area	Mapping
OWASP API	API1: Broken Object Level Authorization

Framework Area	Mapping
Primary Control	Object-level authorization
Evidence Result	BOLA/IDOR-style behaviour observed in lab

8. Sanitized Output Style for GitHub

When documenting this evidence publicly, use placeholders instead of live values. The goal is to prove methodology and security understanding without exposing secrets or private data.

```
Authorization: Bearer <REDACTED_TOKEN>
Cookie: <REDACTED_COOKIE>
email: lab-user@example.com
password: REDACTED
object_id: <CONTROLLED_LAB_ID>
redirect_uri: <REDACTED_OR_LAB_CALLBACK>
```

9. GitHub Redaction Checklist

- Bearer tokens and JWT values must be blurred or replaced with <REDACTED_TOKEN>.
- Email addresses, phone numbers, user IDs, and object identifiers should be blurred when they are not required for understanding the evidence.
- Authorization headers, cookies, session values, OAuth codes, refresh tokens, access tokens, and client secrets must never be visible in public GitHub screenshots.
- If a screenshot contains personally identifiable data, crop the view or blur the affected rows before publication.

10. Publication Note

This report is designed for GitHub portfolio use. It describes authorized lab testing only and avoids production claims. The embedded screenshots have been treated as lab evidence and should remain redacted before upload.